

Pramo Jewels

Security Architecture Document

Document ID: PJ-SEC-001

Version: 1.0

Status: Approved for Development

Field	Value
Project	Pramo Jewels Premium E-Commerce Platform
Purpose	Define the end-to-end security architecture, controls and governance
Audience	Security Architects, Developers, DevOps, QA, Operations
Version	1.0

1. Security Objectives

Protect customer identities, orders, payments and business data using defense-in-depth while maintaining availability and compliance.

2. Security Layers

Client Security → CDN/WAF → HTTPS/TLS → Reverse Proxy → Laravel API → Authentication & RBAC → Database → Encrypted Backups → Monitoring.

3. Identity & Access Management

Laravel Sanctum, Role-Based Access Control, least privilege, strong password policy, optional MFA roadmap, secure session lifecycle.

4. Application Security

Input validation, output encoding, CSRF protection, XSS prevention, SQL injection prevention through ORM/parameterized queries, secure file uploads.

5. Data Protection

TLS 1.2+, encryption at rest for sensitive data, password hashing (Argon2id/Bcrypt), secure secrets management, data minimization.

6. Payment Security

Never store card data. Delegate sensitive payment processing to the payment gateway. Validate payment webhooks and use idempotency.

7. API Security

HTTPS only, bearer tokens, rate limiting, request validation, API versioning, standardized error responses, audit logging.

8. Infrastructure Security

Firewalls, WAF, secure network segmentation, hardened servers, automatic OS updates, restricted administrative access.

9. Monitoring & Incident Response

Centralized logging, anomaly detection, alerting, audit trails, incident classification, forensic log retention and post-incident reviews.

10. Backup & Recovery Security

Encrypted backups, off-site storage, periodic restore testing, controlled access and documented recovery procedures.

11. Compliance

Follow OWASP ASVS principles, OWASP Top 10 mitigations, applicable privacy regulations, secure development lifecycle and dependency management.

12. Security Governance

Regular vulnerability assessments, penetration testing before production, dependency scanning, code reviews and quarterly security audits.